SECURITY DOSSIER

Your data stays on your premises. Here is how, point by point.

An AI installed on site, also called sovereign AI or on-premise AI, is only worth having if every measure can be verified. This page is written for the IT manager, the commander or the partner who has to answer for security. What is fixed at installation is stated as such, and so is what has not been done yet.

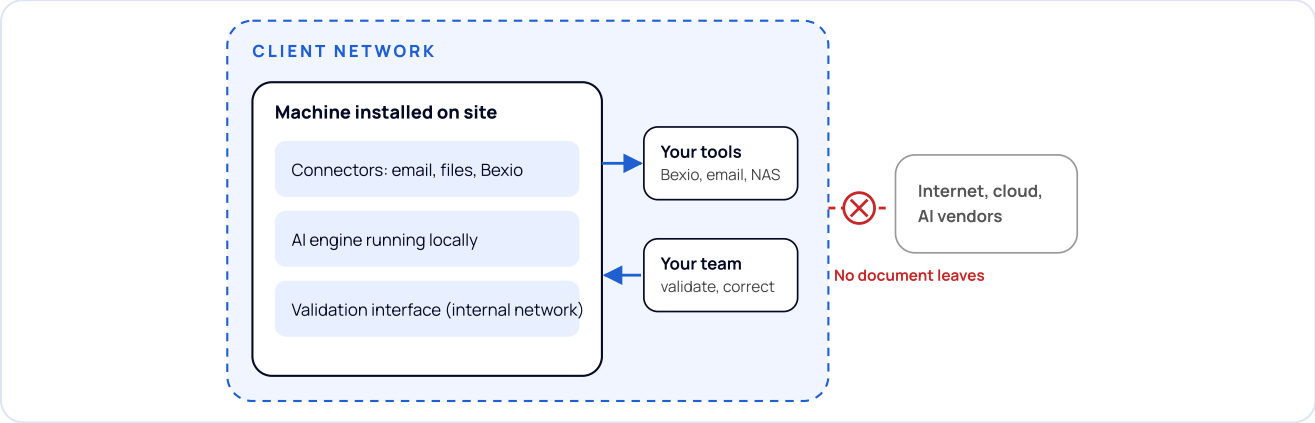
Summary for management

1. **Where the data is processed.** On a machine installed on your premises, on your network, with no call to an external service during processing.
2. **Architecture.** Three building blocks on a single machine: the connectors to your tools, the AI engine, and the validation interface.
3. **Encryption.** Encryption of the disk at rest and of the exchanges in transit on your network.
4. **Access control and logging.** You decide who accesses the system; every action is logged on your premises.
5. **Backups.** Backups are made on your own storage media, according to your policy.
6. **Updates.** Scheduled with you, applied on site or through an access that you open for the duration of the intervention.
7. **End of contract.** The machine and the data stay with you. The system keeps working.
8. **FADP and professional secrecy.** Designed to comply with the Swiss Federal Act on Data Protection (FADP): the data does not leave your walls and is not passed on to any third party.
9. **Penetration test.** No independent penetration test has been carried out yet; it will be documented here when it takes place.

This dossier is not legal advice. Points marked in yellow are being confirmed and will be replaced in the next version, dated and numbered.

PAGE 2

Architecture and data flows



Where the data is processed

On a machine installed on your premises, on your network, with no call to an external service during processing.

- The system is installed on a dedicated machine in your offices, supplied with it: an Apple Mac mini (M4 Pro chip, 64 GB unified memory), the size of a book.
- While a document is being processed, no request is sent to any external service: not to an AI model provider, not to LX Studio.
- The processed documents, the results and the logs stay on this machine's disk.
- The connectors to your tools (Bexio, email, folders) talk to those tools from your network, with your accounts. The list of active connectors and their data flows is recorded in the dossier at installation.

Architecture

Three building blocks on a single machine: the connectors to your tools, the AI engine, and the validation interface.

- Connectors: they read your sources (email, folders, accounting software) and write the validated results back into them.
- Engine: open AI models (Llama and Qwen families), run locally on the machine by Ollama, with local text recognition (Tesseract) and a Swiss QR-bill reader; the exact names and versions are recorded in the dossier at installation.
- Interface: a web page reachable from your internal network only, where your teams validate or correct.
- None of these building blocks can be reached from outside your network without your explicit authorisation.

PAGE 3

Security measures

Encryption

Encryption of the disk at rest and of the exchanges in transit on your network.

- At rest: the machine's disk is encrypted; the method and the custody of the key are recorded in the dossier at installation.
- In transit: the exchanges between your workstations and the interface, and between the machine and your tools, go through encrypted connections (TLS), with certificates issued for your network and recorded in the dossier.
- Backups, if you request them, are encrypted before being written to your storage medium.

Access control and logging

You decide who accesses the system; every action is logged on your premises.

- User accounts are created and removed by you; integration with your existing directory is assessed at installation.
- Rights follow roles: who can start a processing run, who can validate, who can view the logs.
- Every processing run is logged: user, document, time, result. The logs stay on the machine; their retention period is set with you.
- LX Studio's remote access for support goes through an encrypted tunnel that you authorise at installation and can cut off at any time; every intervention is dated and logged like any other action.

Backups

Backups are made on your own storage media, according to your policy.

- The system sends no backup outside your network.
- A scheduled backup runs on the machine; you choose the storage medium (NAS, server, disk) and the frequency. The restore procedure is described in the dossier handed over at installation.
- Processed data can be purged from the machine after validation, according to the period you set.

Updates

Scheduled with you, applied on site or through an access that you open for the duration of the intervention.

- No silent automatic updates: every update is announced, dated and documented.
- Operating system security updates follow your internal policy: who applies them, and when, is set with you at installation.
- The AI models do not change without a test on your real documents and your approval.

End of contract

The machine and the data stay with you. The system keeps working.

- The machine belongs to you from installation; the terms are set out in the quote.
- The code and the documentation are handed over to you, and another provider can take over maintenance.

PAGE 4

Compliance and commitments

FADP and professional secrecy

Designed to comply with the Swiss Federal Act on Data Protection (FADP): the data does not leave your walls and is not passed on to any third party.

- The Swiss Federal Act on Data Protection (FADP, revised in 2023), in force since 1 September 2023, governs the processing of personal data by Swiss companies. The system is designed to comply with it: processing on site, no disclosure to any third party, logging, security measures appropriate to the risk (Article 8 FADP). This is not a certification.
- Professional secrecy (Article 321 of the Swiss Criminal Code) applies in particular to lawyers, notaries, doctors and other health professions, as well as to auditors bound to secrecy under the Swiss Code of Obligations; fiduciaries are bound by their mandate and, often, by the rules of their association. Public administrations fall under official secrecy (Article 320). Processing that lets no document leave your walls is the basic condition for considering it. The final assessment rests with your legal adviser.
- The US CLOUD Act (2018) allows the United States authorities to demand the data that a provider subject to their law controls, wherever it is hosted. A document processed on your machine is under the control of no provider: the question does not arise.
- A record of processing activities and a data protection impact assessment can be documented with you if your activity requires it.

Source: Federal Act on Data Protection (FADP, SR 235.1) and Swiss Criminal Code (SR 311.0, Articles 320 and 321), consolidated texts on fedlex.admin.ch, English translation for information only; Federal Data Protection and Information Commissioner (FDPIC), https://www.fedlex.admin.ch/eli/cc/2022/491/en

Contractual commitments

- No processed data leaves the client's network during processing.
- No remote access by LX Studio without the client's authorisation, which the client can cut off at any time; every intervention is dated and logged.
- The machine, the code and the documentation remain with the client at the end of the contract.
- Every update is announced, dated and documented.

Contact

Tanguy Lachat, LX Studio
Rue des Romains 25, 2854 Bassecourt
contact@lxstudio.ch · 078 703 88 00
https://lxstudio.ch/en/security